



Securing Access

AWS Academy Cloud
Architecting



Introduction

Securing Access

Module objectives

This module prepares you to do the following:

- Describe the security principles in the AWS Cloud.
- Explain the purpose of AWS Identity and Access Management (IAM) users, groups, and roles.
- Explain how IAM policies determine permissions in an AWS account.

Module overview

Presentation sections

- Security principles
- Authenticating and securing access
- Authorizing users
- Parts of an IAM policy

Activity

- Examining IAM Policies

Knowledge checks

- Knowledge check
- Sample exam question

Hands-on labs in this module

Guided lab

- Exploring AWS Identity and Access Management (IAM)

As a cloud architect:



- I need to apply security best practices when I grant access to cloud resources so that I can minimize the risk of unwanted access at each layer of an architecture.



Security principles

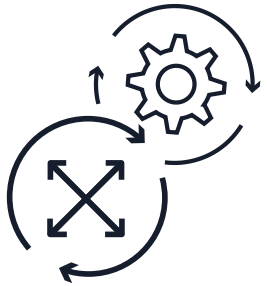
Securing Access

AWS shared responsibility model

Customer Responsible for security IN the cloud	Customer data		
	Platform, applications, identity and access management		
	Operating system, network and firewall configurations		
	Client-side data encryption and data integrity, authentication	Server-side encryption (file system and/or data)	Networking traffic protection (encryption, integrity, identity)

AWS Responsible for security OF the cloud	AWS foundation services			
	Compute	Storage	Database	Networking
	AWS Global Infrastructure			
	Regions	Availability Zones	Edge locations	

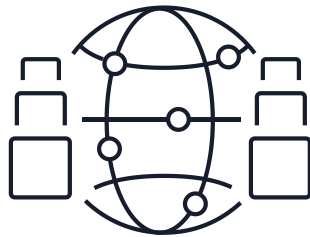
Security is a Well-Architected Framework pillar



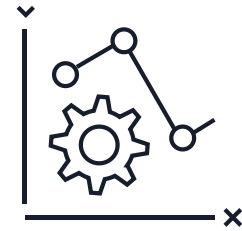
Operational
Excellence



Security



Reliability



Performance
Efficiency



Cost
Optimization



Sustainability

Design principles for the security pillar



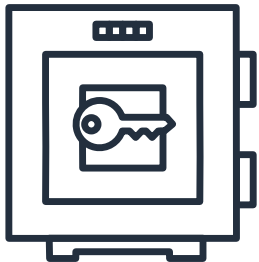
Implement a strong identity foundation.



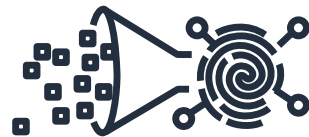
Protect data in transit and at rest.



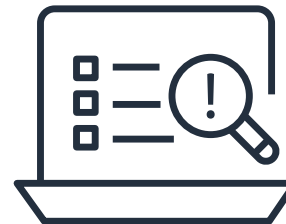
Apply security at all layers.



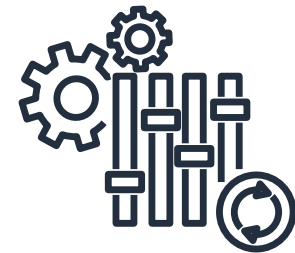
Keep people away from data.



Maintain traceability.

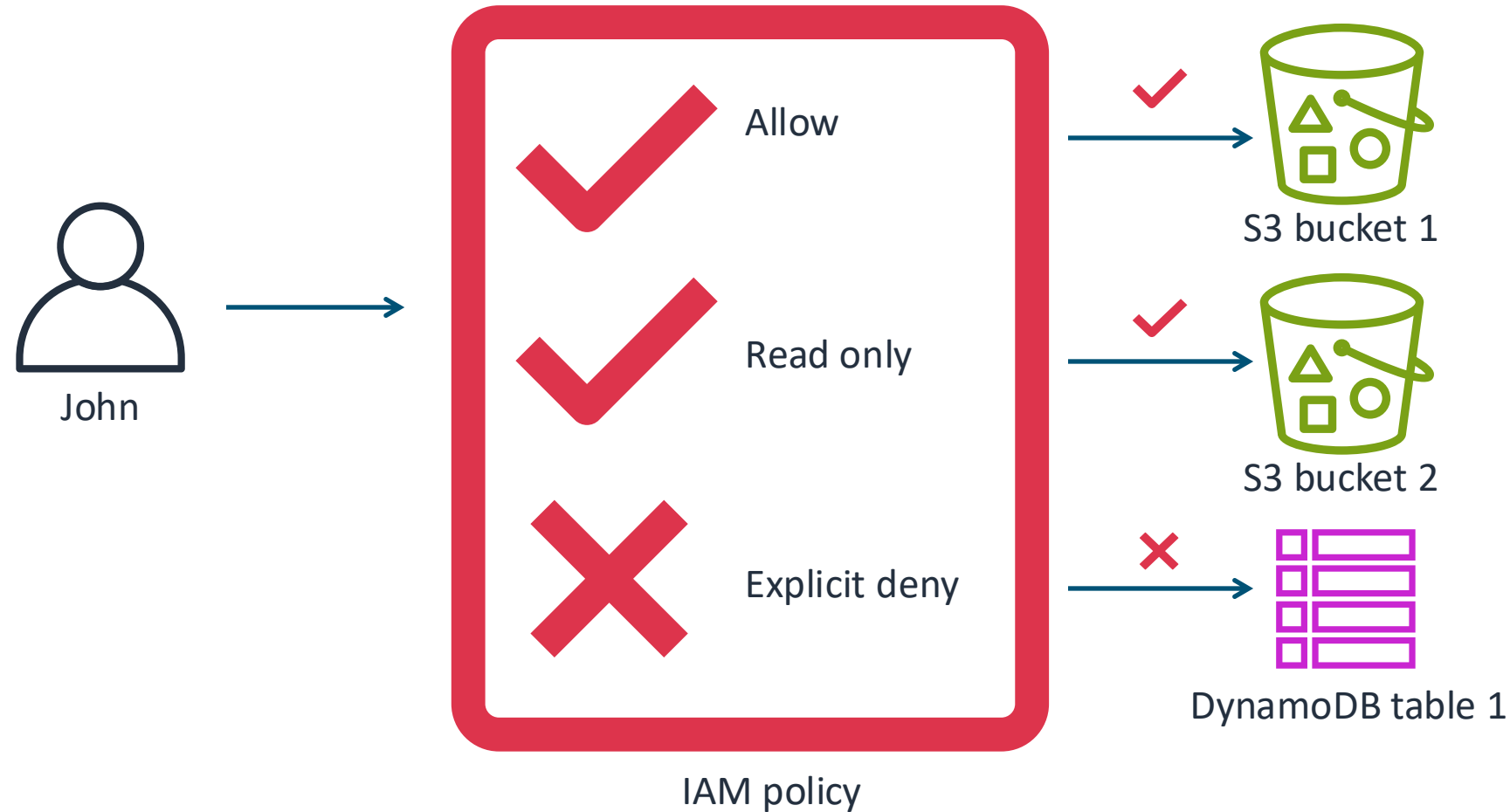


Prepare for security events.

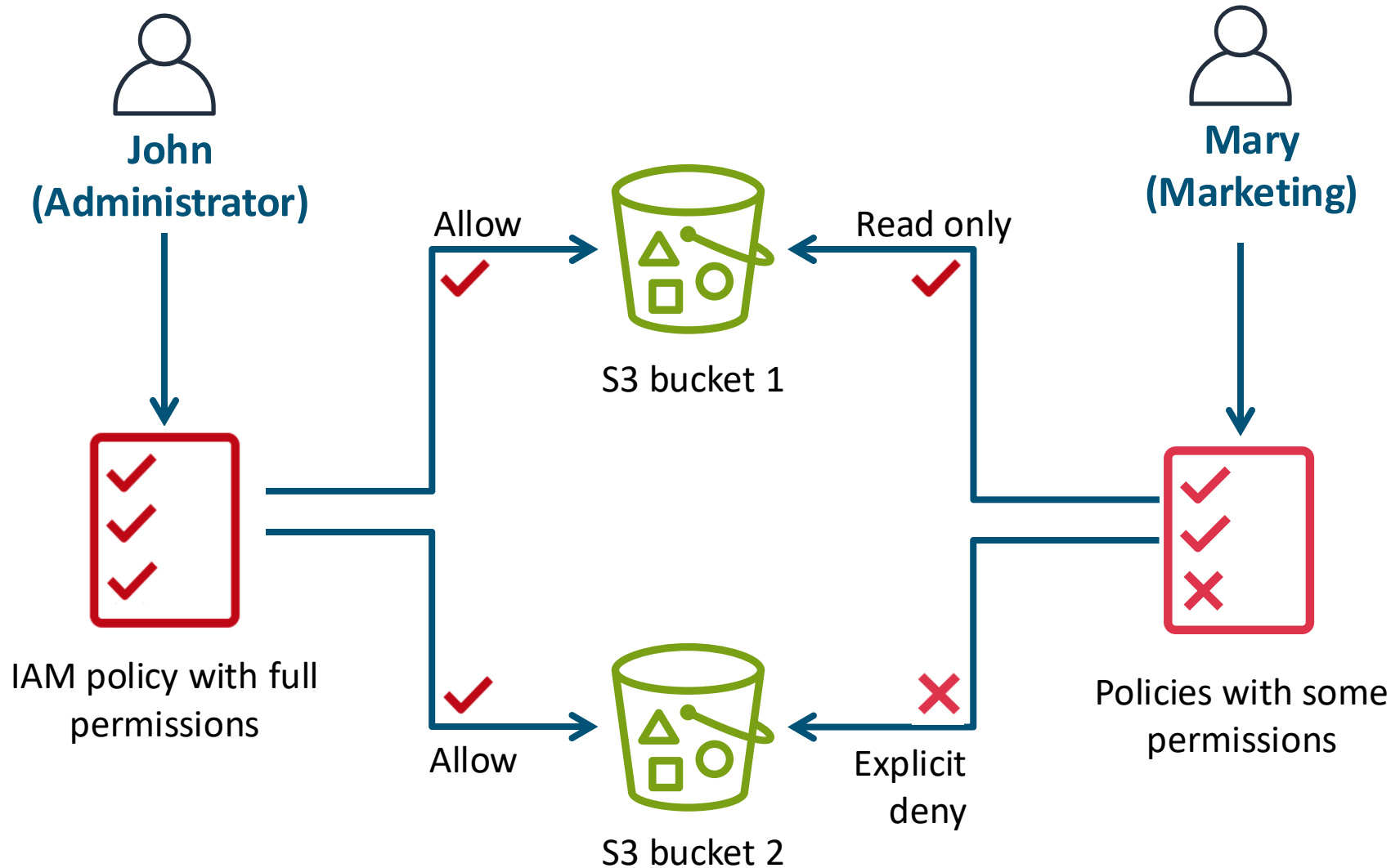


Automate security best practices.

User permissions to access resources



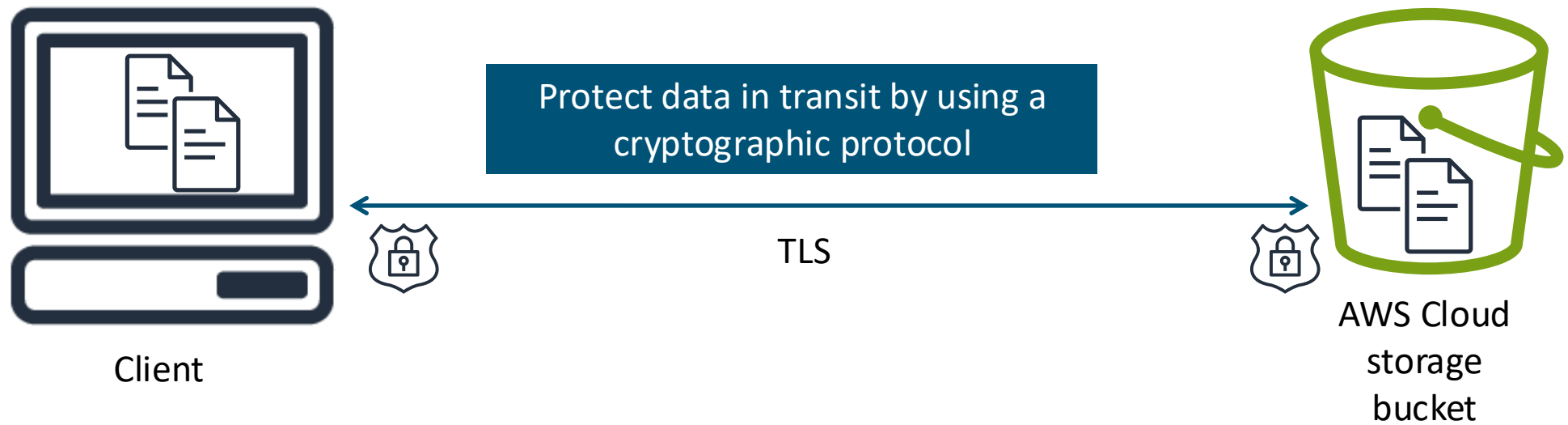
Principle of least privilege



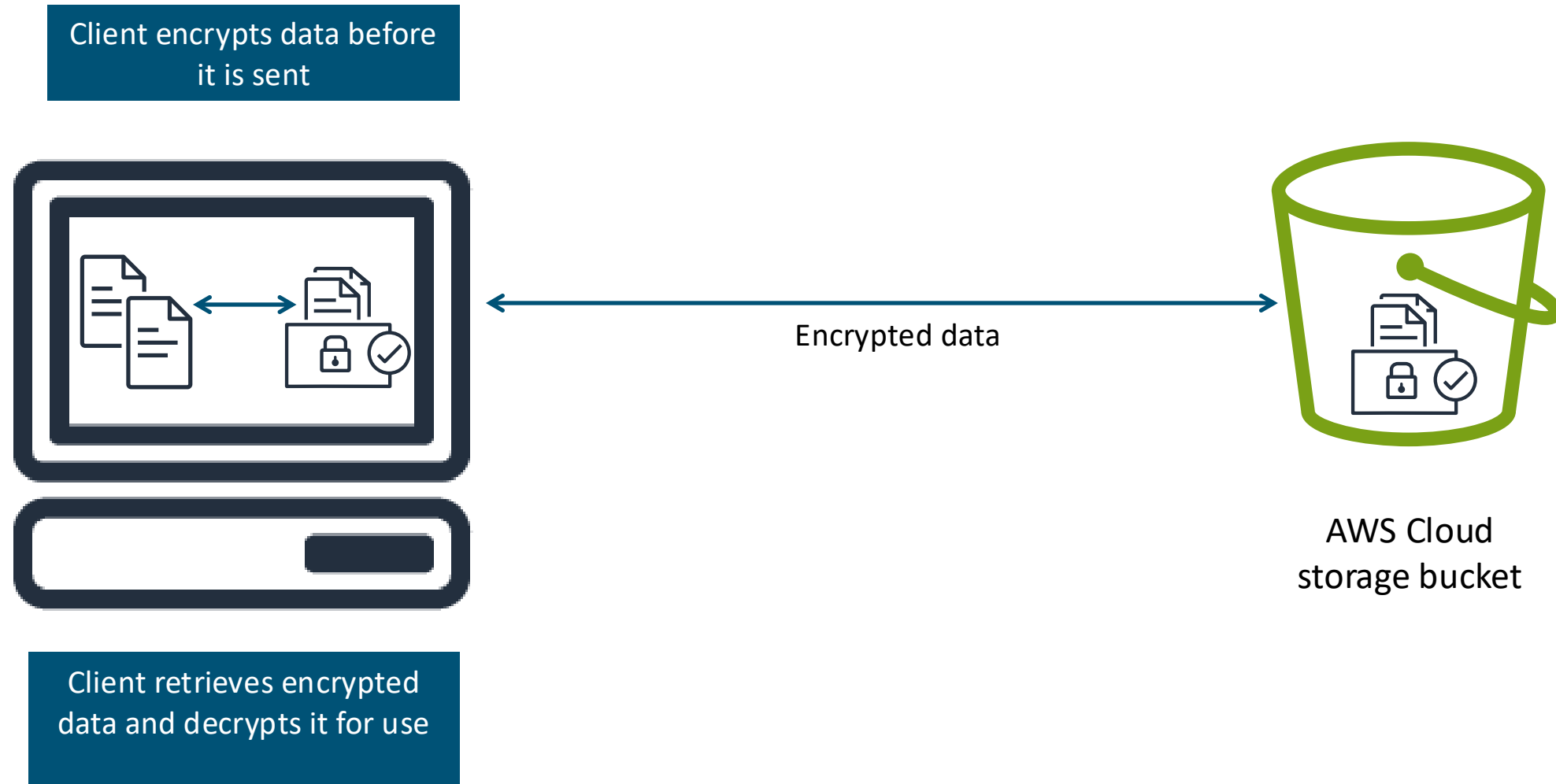
Best practices:

- Grant only the permissions that are required to perform a task.
- Start with a minimum set of permissions.
- Grant additional permissions as necessary.
- Revoke unnecessary permissions.

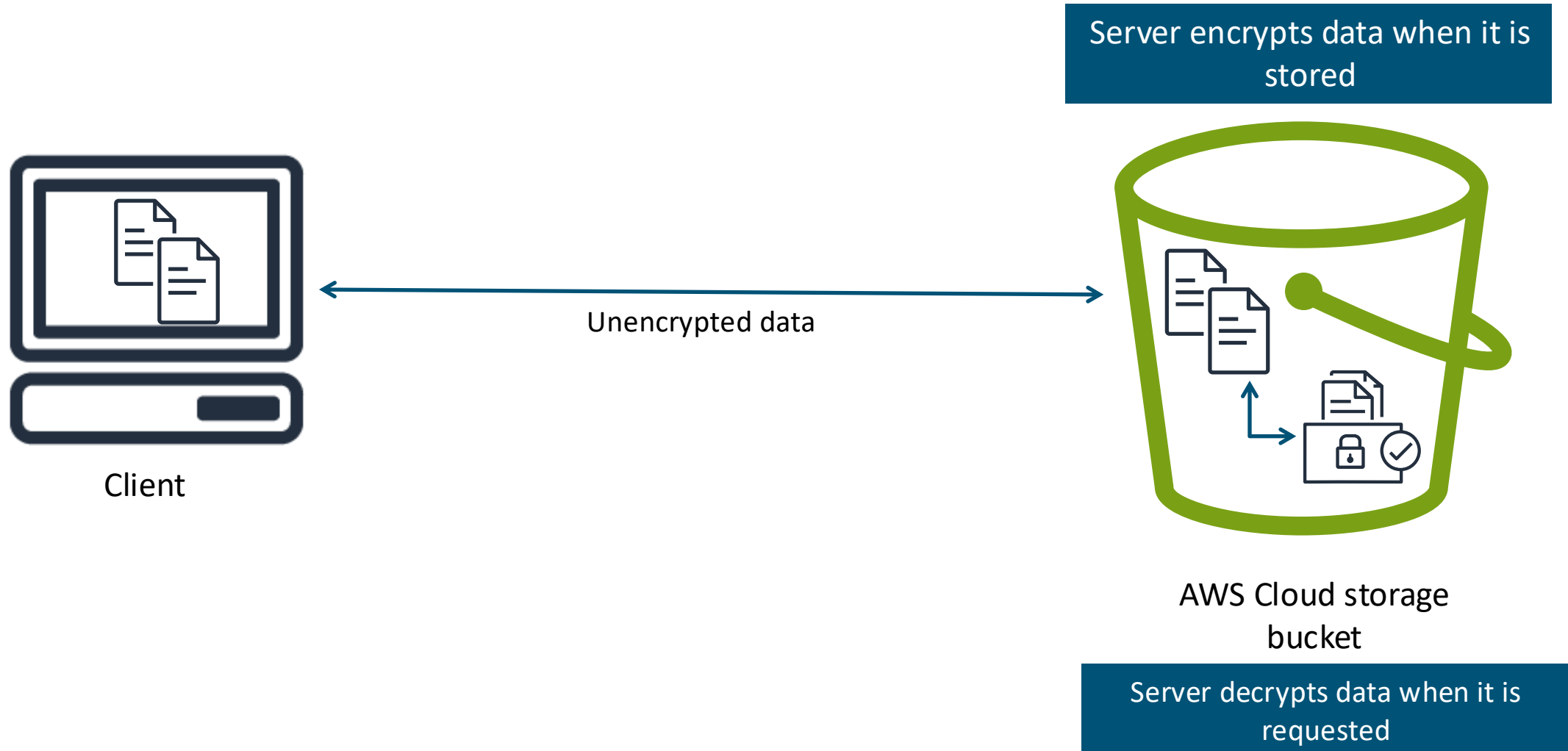
Use encryption



Protecting data at rest with client-side encryption



Protecting data at rest with server-side encryption



Key takeaways: Security principles



- Security and compliance are shared responsibilities between AWS and customers.
- The security pillar of the Well-Architected Framework provides design principles to architect secure solutions.
- The principle of least privilege is a key part of implementing a strong identity foundation.
- Another key security design principle is protecting data at rest and in transit. Encryption is one important mechanism for protecting data.



Authenticating and securing access

Securing Access

Authentication and authorization

Authentication

Who is requesting access to the AWS account and the resources in it?

- It's important to establish the identity of the requester through credentials.
- The requester could be a person or an application.

Authorization

After the requester has been authenticated, what should they be allowed to do?

- Determine whether to allow or deny the request.

AWS Identity and Access Management (IAM)



IAM

- Controls individual and group access to your AWS resources
- Integrates with other AWS services
- Provides federated identity management
- Supports multi-factor authentication (MFA)
- Allows granular permissions

IAM terminology

Term	Definition
IAM resource	User, group, role, policy and identity-provider objects stored in IAM
IAM entity	IAM resource objects that are used by AWS for authentication (users and roles)
IAM identity	IAM resource objects that can be authorized in policies to perform actions and access resources (user, group, or role)
Principal	Person or application that can sign in and make requests to AWS

Using IAM to control access to AWS resources



IAM user

A person or application that can authenticate with an AWS account

IAM group

A collection of IAM users who are granted identical authorization

IAM role

An identity that is used to grant a temporary set of permissions to make AWS service requests

IAM policy

The document that defines which resources can be accessed and the level of access to each resource

IAM credentials for authentication

Action	Credentials needed
Sign in to the AWS Management Console	Username and password
Run commands from the AWS Command Line Interface (AWS CLI)	AWS access key*
Make programmatic calls to AWS	AWS access key*

*An AWS access key is a combination of an access key ID and a secret key.

Best practices to secure access

- Follow the principle of least privilege.
- Enable Multifactor authentication (MFA).
- Require human users to access AWS by using temporary credentials.
- Rotate access keys for use cases that require long-term credentials.
- Use strong, complex passwords.
- Secure local credentials.
- Use AWS Organizations.
- Enable AWS CloudTrail.
- Protect the root user.

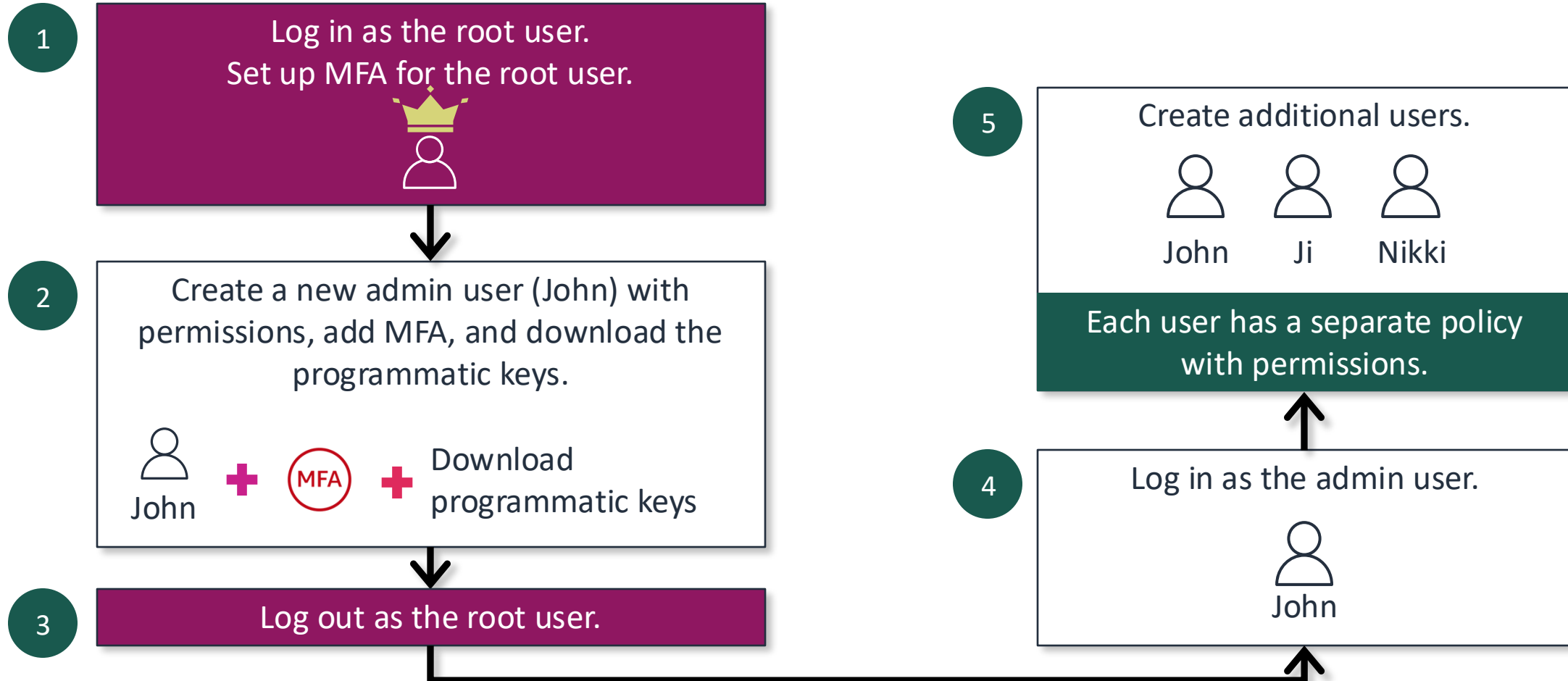
Protecting the root user

- For daily tasks, create an administrative user in AWS IAM Identity Center (successor to AWS Single Sign-On).
- Only use the root user for tasks that other users cannot perform.

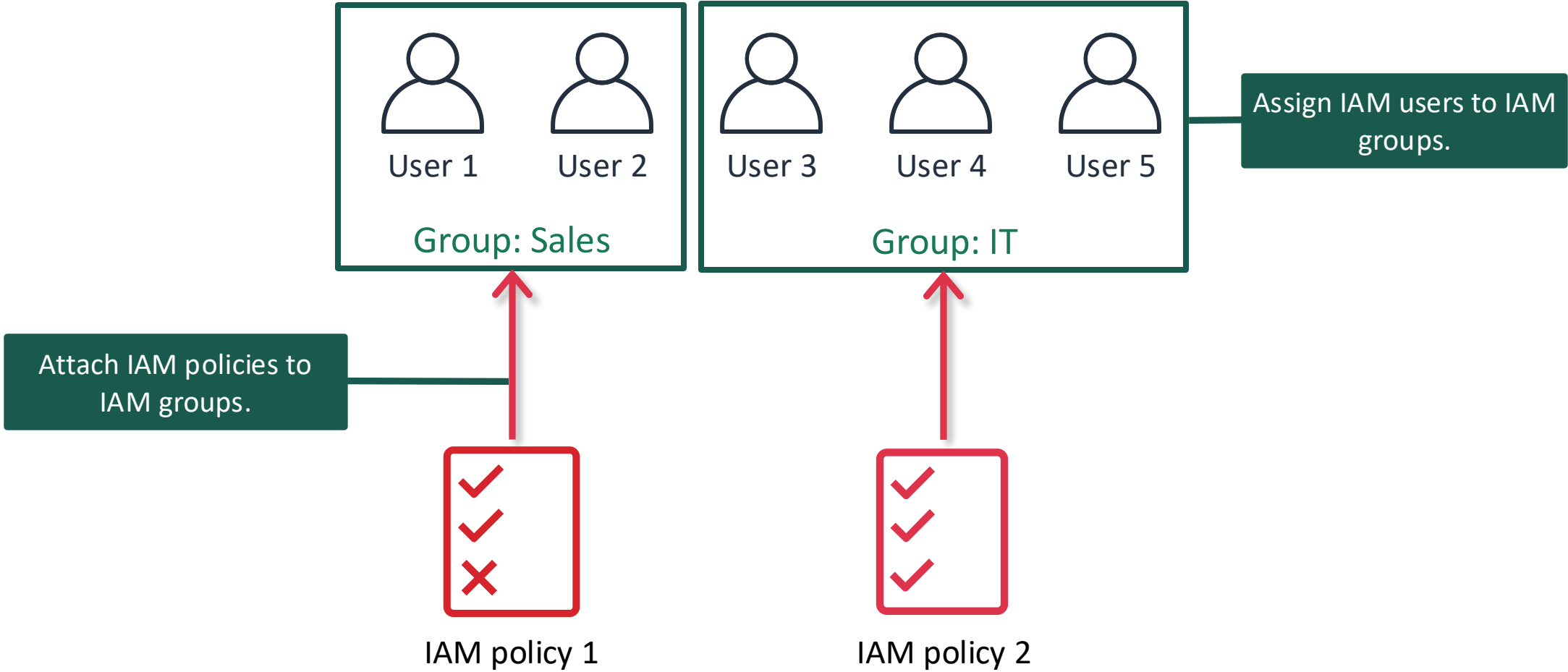
Steps to set up an admin user

As the root user, create an admin user.

Use the admin user for daily tasks.



Best practices: IAM users and groups



IAM roles

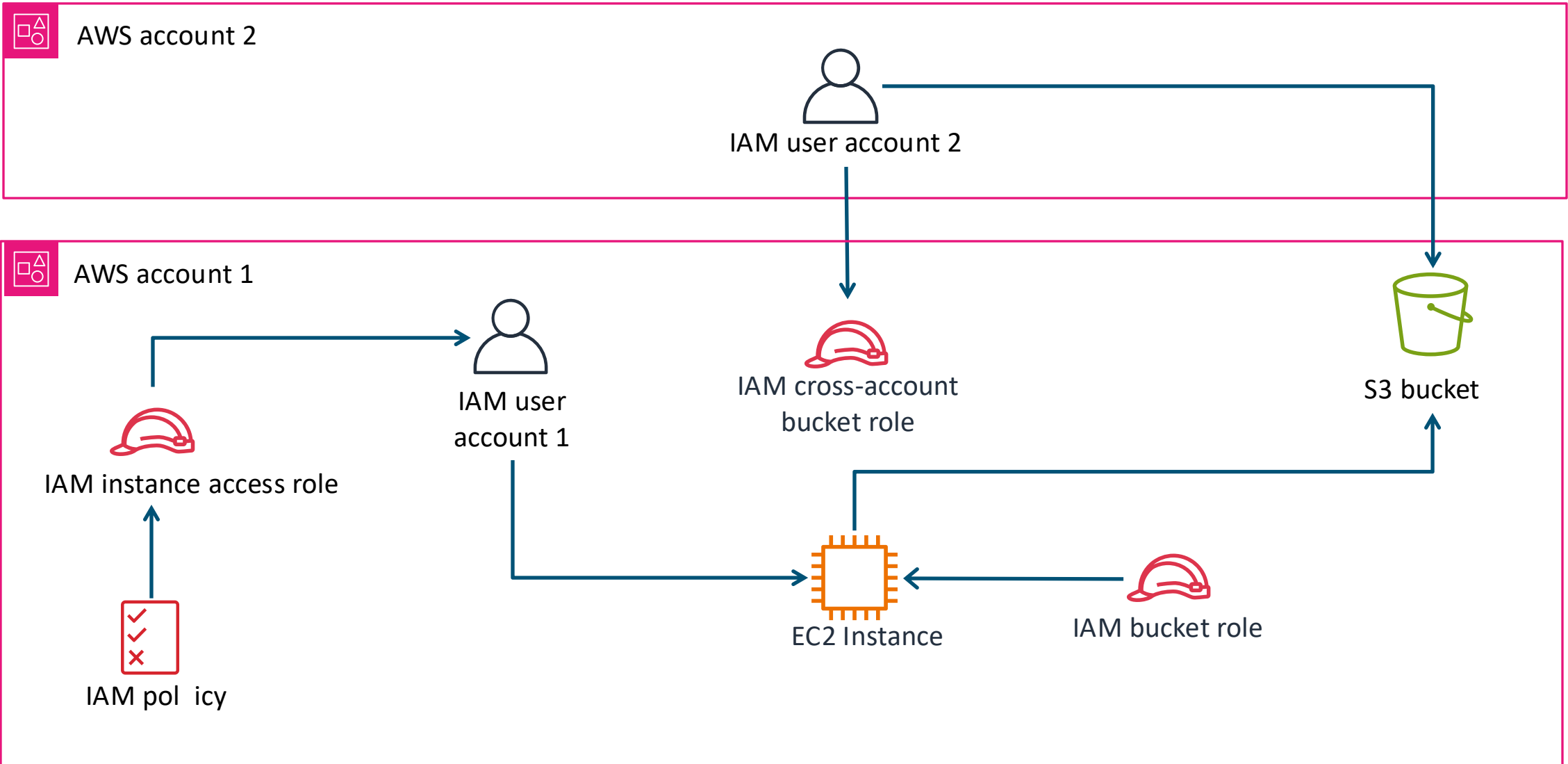
Characteristics

- Provides temporary security credentials
- Isn't uniquely associated with one person
- Can be assumed by a person, application, or service
- Is often used to delegate access

Common use cases

- Application that runs on Amazon Elastic Compute Cloud (Amazon EC2)
- Cross-account access for an IAM user
- Mobile applications

Three examples of using an IAM role



Key takeaways: Authenticating and securing access



- Use the IAM service to configure fine-grained access control to AWS resources.
- The account root user has full access to all AWS account resources. Don't use the root user for day-to-day interactions.
- A best practice is to attach IAM policies to IAM groups and then assign IAM users to these IAM groups.
- An IAM role provides temporary security credentials. With a role, you can define a set of permissions to access the resources that a user or service needs.



Authorizing users

Securing Access

IAM policies and permissions

Use policies to fine-tune the permissions that are granted to principals.

Two types of policies:

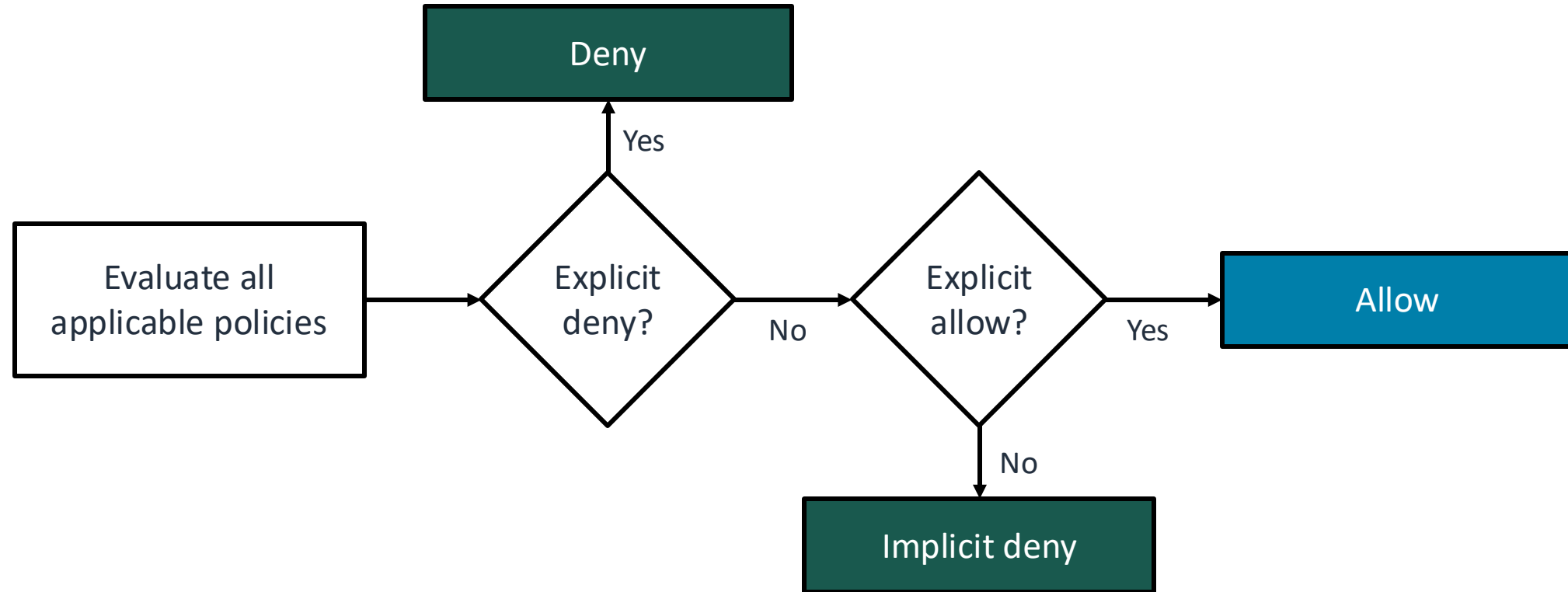
- **Identity-based:** Attach to an IAM user, group, or role.
- **Resource-based:** Attach to an AWS resource.

Define permissions in IAM policy documents.

- The document is formatted in JSON.
- The policy defines which resources and operations are allowed or denied.
- Follow the principle of least privilege.



Determining permissions at the time of request



Identity-based and resource-based policies

Identity-based

(Attached to an *IAM user, group, or role*)

What does a particular identity have access to?

Carlos	Resource	Read	Write	List
	Resource X	Allow	Allow	Allow
Richard	Resource	Read	Write	List
	Resource Y	Allow	N/A	N/A
	Resource Z	Allow	N/A	N/A
Managers	Resource	Read	Write	List
	Resource X	N/A	N/A	Allow
	Resource Y	N/A	N/A	Allow
	Resource Z	N/A	N/A	Allow

Resource-based

(Attached to an *AWS resource*)

Who has access to a particular resource?

Resource X	User	Read	Write	List
	Ana	Allow	Allow	Allow
	Akua	Allow	Allow	Allow
Resource Y	User	Read	Write	List
	Paulo	Allow	Allow	Allow
	Nikki	Allow	N/A	N/A
	Mateo	N/A	Allow	Allow

Policies: Example 1

Identity-based
(Attached to an *user, group, or role*)

Bob

Resource	Get	Put	List
Bucket X	Allow	Allow	Allow
Bucket Y	N/A	N/A	Allow

Resource-based
(Attached to an *AWS resource*)

Bucket X

User	Get	Put	List
Bob	Allow	Deny	Allow

Bucket Y

User	Get	Put	List
Bob	Allow	N/A	Allow

Can Bob GET, PUT, or LIST for bucket X?

The identity-based policy allows him to use the GET, PUT, and LIST APIs for bucket X. However, the resource-based policy for bucket X allows him to use GET and LIST, but denies the ability to use PUT. This means that Bob cannot PUT objects into bucket X, even though his identity-based policy allows it.

Policies: Example 2

Identity-based
(Attached to an *user, group, or role*)

Bob

Resource	Get	Put	List
Bucket X	Allow	Allow	Allow
Bucket Y	N/A	N/A	Allow

Resource-based
(Attached to an *AWS resource*)

Bucket X

User	Get	Put	List
Bob	Allow	Deny	Allow

Bucket Y

User	Get	Put	List
Bob	Allow	N/A	Allow

Can Bob GET or LIST for bucket Y?

The identity-based policy allows the LIST action but doesn't explicitly allow or deny the GET and PUT actions on bucket Y. The resource-based policy for bucket Y allows Bob to use GET and LIST, but doesn't specify the PUT action. Therefore, Bob can read objects from the bucket, even though his identity-based policy doesn't explicitly allow it.

Key takeaways: Authorizing users



- A policy defines permissions for the identity or resource that it's associated with.
- IAM provides two types of policies: identity-based, which is attached to an IAM principal, and resource-based, which is attached to an AWS resource.
- Permissions in policies determine whether a request is allowed or denied.
- By default, all requests are denied. An explicit allow overrides the default deny; an explicit deny overrides any explicit allow.



Parts of an IAM policy

Securing Access

IAM policy document structure

Element	Information
Version	Version of the policy language that you want to use
Statement	Defines what is allowed or denied based on conditions
Effect	Allow or deny
Principal	For a resource-based policy, the account, user, role, or federated user to allow or deny access to. For an identity-based policy, the principal is implied as the user or role that the policy is attached to.
Action	Action that is allowed or denied Example: "Action": "s3:GetObject"
Resource	Resource or resources that the action applies to Example: "Resource": "arn:aws:sqs:us-west-2:123456789012:queue1" (ARN = AWS resource name)
Condition	Conditions that must be met for the rule to apply

Example: resource-based policy

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": ["dynamodb:*", "s3:*"],
    "Resource": [
      "arn:aws:dynamodb:region:account-number-without-hyphens:table/course-notes",
      "arn:aws:s3:::course-notes-web",
      "arn:aws:s3:::course-notes-mp3/*"]
  },
  {
    "Effect": "Deny",
    "Action": ["dynamodb:*", "s3:*"],
    "NotResource": [
      "arn:aws:dynamodb:region:account-number-without-hyphens:table/course-notes",
      "arn:aws:s3:::course-notes-web",
      "arn:aws:s3:::course-notes-mp3/*"]
  }
]
```

← Explicitly allow any (*) DynamoDB or S3 action on the DynamoDB table course-notes, the S3 bucket course-notes-web and any object in the S3 bucket course-notes-mp3.

← Deny any (*) DynamoDB or S3 action on tables or S3 buckets except for those listed under NotResource.

Example: Identity-based policy

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "iam:*LoginProfile",
      "iam:*AccessKey*",
      "iam:*SSHPublicKey*"
    ],
    "Resource": [
      "arn:aws:iam::account-id-without-hyphens:user/${aws:username}"
    ]
  }]
}
```

The Action element lists all the actions that are allowed by the Effect: Allow.

The Resource element lists the AWS resources that the allowed actions can be performed on.

Example: Cross-account, resource-based policy

Policy created by account A

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Sid": "AccountBAccess1",
    "Principal": {"AWS": "111122223333"},
    "Effect": "Allow",
    "Action": "s3:*",
    "Resource": [
      "arn:aws:s3:::DOC-EXAMPLE-BUCKET",
      "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*"
    ]
  }
}
```

Account number of Account B

Allow account B to take any S3 action on the DOC-EXAMPLE-BUCKET.

Activity: Examining IAM Policies



- IAM policy statements are presented on the following 3 slides.
- Answer the questions as they relate to each IAM policy.

Activity: IAM policy analysis (1 of 3)

Consider this IAM policy, and then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": [
      "iam:Get*",
      "iam:List*"
    ],
    "Resource": "*"
  }
}
```

1. Which AWS service does this policy grant access to?

Answer: The IAM service.

2. Does the policy allow the user to create an IAM user, group, policy, or role?

Answer: No. Access is limited to *get* and *list* requests. The policy effectively grants read-only permissions.

3. What are at least three specific actions that the iam:Get* action allows?

Answer: iam:Get* allows actions such as GetGroup, GetPolicy, and GetRole.

Activity: IAM policy analysis (2 of 3)

Consider this IAM policy, and then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "ec2:TerminateInstances",
    "Resource": "*"
  },
  {
    "Effect": "Deny",
    "Action": "ec2:TerminateInstances",
    "Condition": {
      "NotIpAddress": {
        "aws:SourceIp": [
          "192.0.2.0/24",
          "203.0.113.0/24"
        ]
      }
    }
  },
  {
    "Resource": "*"
  }
]
...
}
```

1. Does the policy allow the user to terminate any EC2 instance at any time without conditions?

Answer: No. The policy allows the action but applies a condition.

2. Does the policy allow the user to terminate an EC2 instance from anywhere?

Answer: No. The call must come from one of the two IP address ranges that are specified in *aws:SourceIp*.

3. If the user's IP address is 192.0.2.243, could they terminate an EC2 instance according to this policy?

Answer: Yes, because the 192.0.2.0/24 IP address range includes addresses 192.0.2.0 through 192.0.2.255.

Activity: IAM policy analysis (3 of 3)

Consider this IAM policy, and then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Condition": {
      "StringNotEquals": {
        "ec2:InstanceType": [
          "t2.micro",
          "t2.small"
        ]
      }
    },
    "Resource": "arn:aws:ec2:*:*:instance/*",
    "Action": [
      "ec2:RunInstances",
      "ec2:StartInstances"
    ],
    "Effect": "Deny"
  }]
}
```

1. What actions does the policy allow?

Answer: It doesn't allow any actions. The effect is to *deny*.

2. If the policy also included the following statement, what would be the impact?

```
{
  "Effect": "Allow",
  "Action": "ec2:*"
}
```

Answer: The policy would allow full access to Amazon EC2. However, the policy would only allow a user to launch or start EC2 instances of type t2.micro or t2.small. The allow would be independent of the deny statement with its conditions.

3. If the policy included the statement from question 2, would the user be able to terminate an m3.xlarge instance in the account?

Answer: Yes. The policy would only deny running or starting a t2.micro or t2.small instance.

Key takeaways: Parts of an IAM policy



- IAM policies are stored as JSON documents. Each statement includes information about a single permission.
- Key elements of an IAM policy statement include the effect, action, and resources. Together, these elements determine policy permissions.



Guided lab: Exploring AWS Identity and Access Management (IAM) (Exploring IAM lab)

Exploring IAM lab tasks:



- In this lab, you perform the following main tasks:
 - Experiment with IAM policies
 - Add users to IAM groups
 - Use the IAM sign-in URL

Debrief: Exploring IAM

- Where do you access the AWS Identity and Access Management (IAM) service?
- What happens when a managed policy is updated?



Module wrap-up

Securing Access

Module summary

This module prepared you to do the following:

- Describe the security principles in the AWS Cloud.
- Explain the purpose of IAM users, groups, and roles.
- Explain how IAM policies determine permissions in an AWS account.

Considerations for the cafe

- Discuss how you as a cloud architect might advise the café based on the key cloud architect concern presented at the start of this module.



Module knowledge check



- The knowledge check is delivered online within your course.
- The knowledge check includes 10 questions based on material presented on the slides and in the slide notes.
- You can retake the knowledge check as many times as you like.

Sample exam question

A team of developers needs access to several services and resources in a virtual private cloud (VPC) for 9 months. Team members are likely to change during the project. Which option fulfills this requirement and follows key security principles?

Identify the key words and phrases before continuing.

The following are the key words and phrases:

- Team of developers likely to change
- Needs access for 9 months
- Follows key security principles

Sample exam question: Response choices

A **team of developers** needs access to several services and resources in a virtual private cloud (VPC) for **9 months**. Which option fulfills this requirement and **follows key security principles**?

Choice	Response
A	Create a single IAM user for the developer team, and attach the required IAM policies to the user.
B	Create an IAM user for each developer, and attach the required IAM policies to each user.
C	Create an IAM user for each developer, put them all in an IAM group, and attach the required IAM policies to the group.
D	Create a single IAM user for the developer team, place it in an IAM group, and attach the required IAM policies to the group.

Sample exam question: Answer

The answer is C.

Choice	Response
--------	----------

C	Create an IAM user for each developer, put them all in an IAM group, and attach the required IAM policies to the group.
---	---



Thank you

Corrections, feedback, or other questions?

Contact us at <https://support.aws.amazon.com/#/contacts/aws-academy>.